

Manual 29 — Software / AI Supply Chain Assurance — Controlled English Master

Status: controlled implementation source. This manual preserves the distinction between binding obligations, published standards, voluntary specifications, and implementation guidance. It does not reproduce protected normative text.

Controlled source hierarchy

- Applicable law, regulation, procurement clause, and contract remain the highest binding layer for the organization and transaction.
- NIST SP 800-218 SSDF Version 1.1 is the final stable secure-development baseline used here.
- NIST SP 800-218A is the final AI community profile used with SSDF 1.1.
- SLSA Version 1.2 is the current approved supply-chain assurance specification.
- CISA and similar sources are implementation guidance unless separately made binding.
- NIST SP 800-218 Rev. 1 / SSDF Version 1.2 remains draft/change-watch only.

Each chapter records applicability, accountable ownership, procedure, evidence, review/test, remediation, and reassessment trigger.

Chapter 01 — Purpose, scope, and source boundaries

Define the software, model, component, supplier, product, jurisdiction, contractual, and acquisition scope before selecting controls. Evidence: approved scope statement and source register. Owner: Supply Chain Assurance Lead. Review on material scope or source change.

Chapter 02 — Supplier/component ecosystem inventory

Maintain an owned inventory linking material suppliers, software packages, models, APIs, data sources, build services, hosting, and product dependencies. Evidence: supplier/component register and dependency map. Owner: Third-Party Risk Manager. Reconcile against procurement and engineering records.

Chapter 03 — Secure-development governance and accountability

Establish secure-development policy, accountable roles, segregation of duties, escalation paths, exception authority, and measurable objectives. Evidence: policy, RACI, charters, and exception register. Owner: Engineering Security Executive.

Chapter 04 — SSDF organizational preparation

Map applicable SSDF practices into organization-specific procedures, tooling, training, security requirements, and supplier expectations without representing NIST guidance as certification. Evidence: SSDF implementation matrix. Owner: Secure SDLC Program Manager.

Chapter 05 — Development-environment security

Maintain approved security baselines for developer, build, test, model-training, and related engineering environments, including access, configuration, patching, monitoring, and change governance appropriate to risk. Evidence: baseline and review records. Owner: Platform Security Lead.

Chapter 06 — Source-code and repository governance

Use controlled repositories with defined ownership, authenticated access, branch protection, review policy, auditability, retention, and recovery controls. Evidence: repository settings and audit records. Owner: Source Control Administrator.

Chapter 07 — Identity, access, and privileged build administration

Apply least privilege, managed identities, appropriate strong authentication, periodic access review, and controlled emergency access across source, build, registry, signing, model, and data platforms. Evidence: access review records. Owner: IAM Lead.

Chapter 08 — Branch, review, and change controls

Require traceable proposed changes, risk-appropriate reviewer independence, required quality/security checks, controlled merge paths, and documented emergency-change handling. Evidence: change and approval records. Owner: Engineering Manager.

Chapter 09 — Dependency discovery and component inventory

Identify direct, transitive, runtime, build, model, plugin, and tool dependencies through approved discovery methods and assign ownership to material components. Evidence: dependency inventory and reconciliation results. Owner: Product Security Lead.

Chapter 10 — SBOM generation, formats, and lifecycle

Generate and retain machine-readable software bills of materials where required or risk-appropriate, link them to controlled releases, define supported formats, and validate component identity and relationship completeness. Evidence: SBOM files and release associations. Owner: Release Engineering Lead.

Chapter 11 — VEX and vulnerability-status evidence

When vulnerability-status assertions are used, bind each assertion to product/version scope, vulnerability identity, documented rationale, supporting evidence, accountable owner, and review trigger. Evidence: controlled VEX or equivalent records. Owner: Vulnerability Management Lead.

Chapter 12 — Open-source intake and licensing interfaces

Evaluate provenance, maintenance, security history, license obligations, notices, restrictions, and intended distribution/use before approving open-source software, model, or data components. Evidence: intake and license record. Owner: Open Source Program Office.

Chapter 13 — Third-party library and package assurance

Use approved component sources, controlled versions or immutable identifiers where practical, and documented supplier/package acceptance criteria. Evidence: package policy, approved-source records, and release manifests. Owner: Product Security Lead.

Chapter 14 — Build-service and CI/CD security

Govern build and CI/CD platforms through approved configurations, restricted administrative access, protected pipeline definitions, controlled third-party integrations, audit logging, and change review. Evidence: pipeline configuration and audit records. Owner: DevSecOps Platform Lead.

Chapter 15 — Hermetic/reproducible build considerations

Assess undeclared inputs, environment variability, toolchain drift, and reproducibility needs; use hermetic or reproducible techniques where risk, assurance, or contractual requirements justify them. Evidence: build recipe and comparison results. Owner: Build Engineering Lead.

Chapter 16 — Artifact signing and verification

Define signing authority, approved identities/keys, protected signing processes, verification policy, revocation, and consumer verification requirements appropriate to product risk. Evidence: signatures, verification records, and key governance. Owner: Cryptographic Services Owner.

Chapter 17 — Provenance and attestation architecture

Generate provenance or attestations from trusted processes, bind them to immutable artifact identities, preserve relevant source/build/material information, and define verifier policy. Evidence: attestations, verification summaries, and artifact digests. Owner: Supply Chain Assurance Lead.

Chapter 18 — SLSA Build and Source track implementation

Select only applicable SLSA v1.2 track/level targets, document gaps, satisfy requirements before making claims, and distinguish internal maturity statements from external certification. Evidence: requirement matrix and validation records. Owner: Supply Chain Assurance Lead.

Chapter 19 — Secrets, keys, tokens, and signing-material governance

Use approved storage, scoped credentials, rotation, access control, monitoring, and incident procedures for development, build, registry, signing, API, model, and data pipeline secrets. Evidence: vault and rotation records. Owner: Secrets Management Owner.

Chapter 20 — Container, image, and infrastructure component assurance

Use approved component sources, controlled image/IaC versions, vulnerability and integrity checks, lineage records, and risk-based signing/verification for deployable infrastructure artifacts. Evidence: manifests, digests, scan records, and approvals. Owner: Cloud/Platform Security Lead.

Chapter 21 — AI model provenance and model-supply-chain controls

Record model origin, version, provider, training/fine-tuning lineage when available, license/use restrictions, integrity identifiers, evaluation status, deployment owner, and material dependencies. Evidence: model inventory and provenance records. Owner: AI Security Lead.

Chapter 22 — Training/evaluation data provenance

Record source, authority or license, sensitivity, quality controls, transformations, lineage, retention constraints, and use limitations for material training, fine-tuning, retrieval, evaluation, and benchmark data. Evidence: dataset register and lineage records. Owner: Data Governance Lead.

Chapter 23 — AI component, plugin, tool, and agent dependency governance

Inventory AI-supporting components and services, document permissions and trust boundaries, require approved provenance or supplier evidence, and reassess material capability or permission changes. Evidence: component/tool inventory and review records. Owner: AI Platform Security Lead.

Chapter 24 — Third-party model/API/service-provider assurance

Assess provider security, privacy, availability, data handling, incident notification, subcontractors, evidence rights, change notification, exit/portability, and contractual commitments according to risk and applicability. Evidence: due diligence and contract controls. Owner: Third-Party Risk Manager.

Chapter 25 — Vulnerability discovery, prioritization, and response

Correlate identified vulnerabilities to affected products/components, prioritize based on relevant risk factors, assign remediation commitments, validate closure, and retain risk-decision evidence. Evidence: findings, tickets, decisions, and validation. Owner: Vulnerability Management Lead.

Chapter 26 — Package-source and dependency-integrity governance

Apply governance to package namespaces, approved registries, component naming, supplier changes, integrity signals, and unexpected dependency behavior so material component-source anomalies are reviewed and contained. Evidence: registry policy, monitoring records, and review decisions. Owner: Product Security Lead.

Chapter 27 — Release approval, distribution, and rollback

Require defined release gates, artifact identity, required testing, provenance/signature checks, SBOM/VEX where applicable, approval authority, controlled distribution, and rollback readiness. Evidence: release record and artifact manifest. Owner: Release Manager.

Chapter 28 — Incident response and supply-chain compromise handling

Integrate supplier, component, repository, build, signing, model, and data compromise scenarios into incident response, including evidence preservation, affected-artifact identification, trust revocation, required notification, recovery, and corrective action.

Evidence: incident and recovery records. Owner: Incident Commander.

Chapter 29 — Metrics, exceptions, and risk acceptance

Track meaningful measures such as dependency ownership, artifact verification coverage, SBOM coverage, vulnerability aging, supplier-evidence freshness, exception age, and target assurance attainment. Require time-bound risk acceptance. Evidence: dashboards and approvals. Owner: Risk Governance Lead.

Chapter 30 — Assurance, testing, and evidence validation

Perform risk-based independent assurance through evidence inspection, configuration review, artifact/provenance verification, release tracing, and control-operation testing.

Evidence: test plans, workpapers, findings, remediation, and retest records. Owner: Independent Assurance Lead.

Chapter 31 — Localization, accessibility, licensing, and source control

Maintain controlled EN/es-419/pt-BR parity, identify project translations as unofficial, preserve licensing/source boundaries, validate accessibility and rendered layout, and version all release materials. Evidence: parity, accessibility, and source-control records. Owner: Documentation Release Lead.

Chapter 32 — Release roadmap, provenance, checksums, and sequential publication

Build reproducible EN/es-419/pt-BR DOCX/PDF candidates, bind exact SHA-256 identities and artifact digest, perform deterministic QA without regeneration, durably stage exact verified bytes, require published Manual 28, and reconcile publication state only after a fully green exact-head matrix. Evidence: workflow run, artifact, manifest, provenance, staging record, checks, and merge commits. Owner: Release Manager.